

Requirements Gap Analysis – General Features

Internet Banking System | QA Review

#	Identified Gap	Explanation	Question to Ask the Business Analyst
1	Login method is limited to email/password only	The document only mentions email and password for authentication. There is no mention of multi-factor authentication (MFA), which is a standard security expectation for banking systems.	"Is MFA (e.g. SMS OTP, authenticator app) required as part of the login flow, or is email/password sufficient?"
2	Password policy applies only at login — reset/change not covered	The password complexity rules are defined, but there is no requirement for password change, expiry, or history (e.g. cannot reuse last 5 passwords).	"Do password expiry periods or reuse restrictions need to be enforced? What are the rules for the password reset flow?"
3	Account lock duration is fixed but unlock mechanism is unspecified	After 3 failed attempts the account locks for 10 minutes, but it is unclear whether the lock lifts automatically, requires user action (email link), or admin intervention.	"After the 10-minute lockout period, does the account unlock automatically, or does the user need to take an action to regain access?"
4	No requirement defined for successful login behavior	The document describes failure handling (error message, logout) but says nothing about what happens on a successful login — e.g. redirect target, welcome message, or last-login notification.	"What should the system display or do immediately after a successful login? Should the user be shown a dashboard, and should a last-login timestamp be displayed?"
5	"Appropriate error message" is vague	The requirement says the system displays "an appropriate error message" on failed login, but does not specify whether the message should distinguish between wrong email vs. wrong password, or use a generic message for security reasons.	"Should the error message be generic (e.g. 'Invalid credentials') to prevent user enumeration attacks, or can it indicate which field is incorrect?"
6	Scope of 'registered' users is undefined	The document mentions "registered email addresses" but provides no requirements for the registration/onboarding process itself.	"Is user registration in scope for this system? If so, where are the requirements for account creation and email verification?"

#	Identified Gap	Explanation	Question to Ask the Business Analyst
7	Maximum password length is not defined	The requirement states passwords must be at least 8 characters long, but no upper limit is specified. This could lead to inconsistent UI behaviour, database field sizing issues, or potential denial-of-service via extremely long inputs.	"What is the maximum allowed length for a password, and should the system silently truncate or explicitly reject passwords that exceed it?"